ACME'S APPROACH TO REGULATORY AUDITORS

Auditors don't just check for policies—they look for proof that those policies are enforced, reviewed, and traceable to their intent. ACME designed its governance framework so that this evidence naturally arises from regular operations rather than special audit preparation.

When a regulatory audit begins, coordinators from the Access Control Coordinating Council compile an audit package directly from the governance repository. The package includes:

- Architectural Decision Records (ADRs) documenting how each regulatory control is implemented
- The relevant policy definitions tagged with compliance metadata like `sox:access-review` or `gdpr:data-access`
- Version control history showing authorship, review, and approval
- Decision logs showing how those policies perform in production
- Policy review board minutes linking changes to incident reports or access review findings

Because ACME's governance data is continuously updated, creating the audit package is mostly automated. Auditors get read-only access to a secure dashboard that lets them trace each policy from intent (the ADR) to enforcement (decision logs) without direct system access.

During audits, ACCC coordinators and auditors hold structured review sessions. Coordinators show how specific compliance requirements—such as least privilege or purpose limitation—are implemented and tested automatically. Any findings or recommendations are logged as tickets in the incident system, tracked until resolved, and documented as new ADRs when they lead to policy changes.

This approach shifts the relationship between ACME and its regulators. Instead of assembling static evidence for periodic audits, ACME practices ongoing compliance: Its authorization policies, governance records, and operational logs create a living system of accountability. Auditors see not